

Integration Endpoints and Authentication

IDP Audit Engine and Cartograph

VERSION	1.1
Date	August 2026
Author	Maria Azevedo
Status	For implementation. Reconciled against Cartograph's deployed endpoint, 2026-08-24

This document defines the five HTTP flows between Cartograph and the IDP audit engine, the authentication scheme used in both directions, and the failure semantics each side should expect.

Companion documents: *Ingest Payload Contract v1.1*, *Sample Ingest Payload*, *Schema Change Request*.

1. Topology

The audit engine runs on RunPod, co-located with the OCR service. Every page image is sent to OCR, so co-location avoids tens of megabytes of transfer and material latency per packet. Cartograph runs on Heroku. All traffic is HTTPS.

The engine is addressed by a stable custom domain rather than a raw pod URL, so a pod cycle does not change the address.

#	FLOW	DIRECTION	PURPOSE
1	Trigger	Cartograph → Engine	A job is ready for audit
2	Documents	Engine → Cartograph	Fetch fresh signed URLs for the packet
3	Ingest	Engine → Cartograph	Deliver the extraction result
4	Result callback	Cartograph → Engine	Report the outcome of the background import
5	Reconciliation	Engine → Cartograph	Safety-net poll for missed triggers

2. Flow 1: Trigger (Cartograph → Engine)

POST `https://<engine-domain>/integration/trigger`

Fired when a job becomes ready for audit. The engine validates, enqueues, and returns immediately; the audit itself takes minutes and runs asynchronously.

```
{
  "event_type": "audit_request",          // or "correction" | "reaudit"
```

```

"schema_version": "1.0",
"sent_at":        "2026-08-17T14:02:11Z",
"case_ref":       "CAS600142",           // Cartograph Job#ref_number
"job_id":         4821,
"community_id":   67,
"cert_type":      "annual",
"program":        "CT_8_306",
"unit_number":    "2-114",
"effective_date": "2026-07-01",
"documents": [
  { "job_document_id": 99120,
    "filename":        "packet.pdf",
    "document_class":  "verifications",
    "source":          "client_upload",
    "status":          "approved",
    "url":             "https://<presigned>" }
]
}

```

Response: 202 Accepted with {"ok": true, "audit_id": "aud..."}.

Non-2xx means the trigger was not accepted and should be retried.

Retry is required

The engine previously polled Salesforce, which was self-healing. If the engine was down, the next cycle picked the case up. Push is fire-and-forget. A trigger sent during a restart, deploy, or transient failure is a case that is never audited, and nobody discovers it until a reviewer opens a blank checklist.

Please retry on non-2xx with exponential backoff, at least 5 attempts over ~30 minutes.

3. Flow 2: Documents (Engine → Cartograph)

GET https://<cartograph>/api/jobs/{job_id}/documents

Active Storage assigns randomized blob keys, so the engine cannot locate a packet by listing S3, and presigned URLs expire long before a queued job reaches the front of the line. The engine calls this at the moment it starts work to obtain fresh links.

Returns, per document: job_document_id, filename, document_class, source, status, and a signed URL valid for at least 60 minutes.

4. Flow 3: Ingest (Engine → Cartograph)

POST https://<cartograph>/webhooks/runpod_ocr_results

Delivers the full extraction result for one job. Body format is defined in **Ingest Payload Contract v1.1**.

Response: 202 Accepted with {"ok": true, "import_id": "..."}.

The endpoint verifies the signature, enqueues, and returns without performing inserts, staying well inside Heroku's 30-second request limit (H12).

5. Flow 4: Result callback (Cartograph → Engine)

POST https://<engine-domain>/integration/import_result

Because the ingest endpoint returns before the inserts run, its response cannot report what happened. Without this callback, a payload that fails validation in the background fails silently on the engine's side.

```
{
  "import_id":      "imp_01JQ...",
  "job_id":         4821,
  "cert_review_id": 8891,
  "status":         "ok",                // ok | failed | partial
  "created": { "members": 2, "income_records": 2, "paystubs": 2,
               "vois": 1, "assets": 1, "findings": 12 },
  "warnings": [
    "asset_records[0].asset_type collapsed to 'other' (original: Prepaid Card)",
    "household_members[1].date_of_birth could not be parsed"
  ],
  "errors": []                // populated when status != ok
}
```

Populate warnings for every value that collapses to other, every date that fails to parse, and every member that arrives without a relationship. These identify where the engine's vocabulary mapping is lossy. Without them, that information is only recoverable by manual spot-checking.

6. Flow 5: Reconciliation (Engine → Cartograph)

GET https://<cartograph>/api/jobs/audit_pending

Returns jobs that are audit-ready but have no extraction result yet. The engine polls this at low frequency (hourly) as a safety net.

Retry covers a trigger that failed in transit. Reconciliation covers a trigger that was never sent at all: a deploy during the window, a dropped queue entry, or a fault in the trigger condition itself. Without it, a missed case surfaces only when a reviewer opens an unpopulated record.

7. Authentication

HMAC-SHA256 over the raw request body, in both directions. This matches the scheme `webhooks::RunpodOcrController` already verifies in production.

Two details are easy to get wrong and fail as an opaque 401: the digest is **hex with no version prefix**, and the signature covers the **exact bytes transmitted**. Signing a re-serialization of a parsed body produces a different string.

HEADER	VALUE
Content-Type	application/json
X-Timestamp	Unix seconds at send time

HEADER	VALUE
X-Signature	Hex digest, no prefix

```
signed = "{timestamp}.{raw_body}"
header = HMAC_SHA256(secret, signed).hexdigest()
```

Rules

- **Fail closed.** If the signing secret environment variable is unset, return 401. The three existing webhook controllers currently proceed when their secret is missing: Stripe parses unsigned JSON, Resend logs and continues, Auth0 skips the check. This endpoint must not follow that pattern.
- **Reject stale requests.** Any timestamp more than 300 seconds from now is rejected, which prevents replay of a captured request.
- **Compare in constant time.** Use a secure comparison, not ==.
- **Accept two valid secrets during rotation.** The verifier should try a current and a previous secret so either side can rotate without coordinated downtime.

Secrets

Two independent secrets, one per direction, so a compromise in one direction does not expose the other. Delivered via 1Password, separately from these URLs, not over chat.

8. Status codes

STATUS	MEANING
202	Accepted and enqueued (trigger and ingest)
200	Processed synchronously (documents, reconciliation, result callback)
401	Missing or invalid signature, stale timestamp, or unset secret
409	Job not found, community mismatch, or cert review already populated
422	Validation failure. Body names the record index and offending field
413	Payload above the size cap

9. Open items

- Engine domain and final paths: to follow once DNS and TLS are in place.
- Secrets: delivered separately via 1Password.
- Payload size cap: to be agreed. expected to be well under 5 MB for a typical packet.